

Forensic Reconstruction Runbook for Acme Retail Inc.

Scenario

Acme Retail Inc. is a 2,000-employee online clothing retailer running on Huawei Cloud in the TR-Istanbul region. At 03:14 UTC on Tuesday, monitoring systems started firing. This runbook reconstructs the first three hours of the incident using Huawei Cloud services only.

The purpose of this document is to show, step by step, which Huawei Cloud service should be queried, which filter or SQL should be used, and what evidence should be expected at each stage.

Event 1 — 03:14:22 UTC

Cloud Eye CPU Alarm on **prod-checkout-asg**

Situation

Cloud Eye fires an alarm: average CPU on the **prod-checkout-asg** auto-scaling group has climbed to 95% for 5 consecutive minutes.

Huawei Cloud Cloud Eye supports monitoring for ECS and Auto Scaling metrics. ECS metrics can be viewed from Cloud Eye, and Auto Scaling has its own metric namespace. Some deeper OS and process metrics require an installed agent. Huawei Cloud documentation states that Cloud Eye can monitor ECS metrics and that process monitoring can collect CPU usage, memory usage, and opened files for active processes.

Action 1.1 — Open the first Cloud Eye dashboard

Action: Confirm whether the alarm is isolated to the auto-scaling group or caused by a wider infrastructure issue.

Huawei Cloud Service: Cloud Eye

Console Path:

Huawei Cloud Console → Cloud Eye → Server Monitoring / Cloud Service Monitoring → Auto Scaling → prod-checkout-asg

Filter / View:

- Region: TR-Istanbul
- Resource: prod-checkout-asg
- Time range: 03:00–03:30 UTC
- Metric: Average CPU Usage

Expected Evidence:

- CPU average at or above 95% for 5 consecutive minutes.
 - Whether all ECS instances in the AS group are affected or only one instance.
 - Whether Auto Scaling launched new ECS instances.
 - Timestamp alignment with later brute-force and WAF events.
-

Action 1.2 — Check ECS-level metrics after CPU

Action: Check whether the CPU spike is caused by real traffic, network pressure, memory pressure, or abnormal host behavior.

Huawei Cloud Service: Cloud Eye / ECS Monitoring

Console Path:

Huawei Cloud Console → Cloud Eye → Server Monitoring → Elastic Cloud Server → prod-checkout-*

Metrics to Check After CPU:

1. **Network inbound/outbound rate**
To determine whether the checkout service is receiving abnormal traffic.
2. **Memory usage**
To check whether the application is under memory pressure or swapping.
3. **Disk I/O / disk read-write rate**
To detect excessive logging, database interaction, or disk bottlenecks.
4. **Load average / OS-level CPU metrics**
To distinguish application pressure from system/kernel pressure.

Huawei Cloud documentation notes that ECS monitoring metrics can be viewed in Cloud Eye and that OS-level metrics may require an agent.

Expected Evidence:

- If network traffic rises with CPU, the cause may be external load or attack traffic.

- If memory also rises, application resource exhaustion may be occurring.
 - If disk I/O rises sharply, excessive logs or backend dependency failures may be contributing.
 - If only one ECS is affected, it may indicate a bad instance, bad deployment, or local process issue.
-

Action 1.3 — Identify the CPU-consuming process

Action: Determine which process is consuming CPU.

Huawei Cloud Service: Cloud Eye Process Monitoring / AOM / HSS

Console Path Option A:

Huawei Cloud Console → Cloud Eye → Server Monitoring → Elastic Cloud Server → Process Monitoring

Console Path Option B:

Huawei Cloud Console → Application Operations Management (AOM) → Infrastructure Monitoring → Hosts → Processes

Console Path Option C:

Huawei Cloud Console → Host Security Service (HSS) → Servers → Asset Management / Processes

Expected Evidence:

- Process name, PID, CPU usage, memory usage, and command path.
- Whether the process is the checkout application, web server, runtime process, crypto-mining process, or suspicious binary.
- Whether the same process spike appears across all ECS instances or only one host.

Reasoning:

If the process is the normal checkout application and network traffic is high, the CPU alarm may be caused by legitimate or malicious request volume. If the process is unknown, newly created, or running from a suspicious path, the event may indicate host compromise.

Event 2 — 03:18:45 UTC

LTS Brute-Force Login Alarm

Situation

The LTS brute-force alarm fires with this query:

```
SELECT source_ip, COUNT(*) AS attempts
FROM log
WHERE request_uri = '/api/login'
AND status = 401
GROUP BY source_ip
HAVING COUNT(*) > 200
ORDER BY attempts DESC
LIMIT 5;
```

The query identifies source IPs generating more than 200 failed login attempts against [/api/login](#).

Huawei Cloud LTS provides centralized log collection, query, visualization, and storage. It can be used to run SQL-style log analysis and retain logs for investigation.

Action 2.1 — Identify attempted usernames

Action: Pivot from attacker source IP to attempted usernames.

Huawei Cloud Service: Log Tank Service / LTS

Console Path:

[Huawei Cloud Console](#) → [Log Tank Service \(LTS\)](#) → [Log Management](#) → [Log Group: prod-checkout](#) → [Log Stream: application-access](#) → [SQL Query](#)

LTS SQL Query 1 — Attempted usernames by attacker IP

```
SELECT username,
       source_ip,
       COUNT(*) AS failed_attempts
FROM log
WHERE request_uri = '/api/login'
AND status = 401
AND source_ip IN (
  SELECT source_ip
  FROM log
  WHERE request_uri = '/api/login'
  AND status = 401
  GROUP BY source_ip
  HAVING COUNT(*) > 200
)
GROUP BY username, source_ip
ORDER BY failed_attempts DESC
```

LIMIT 50;

Expected Evidence:

- List of usernames targeted by the brute-force source IPs.
 - Whether the attack is password spraying across many users or focused brute force against a small number of accounts.
 - High-risk accounts such as `admin`, `support`, `merchant-admin`, or employee email addresses.
-

Action 2.2 — Check whether any brute-force attempts succeeded

Action: Determine whether the same attacker IPs received HTTP 200 responses on `/api/login` in the last 30 minutes.

Huawei Cloud Service: LTS

Console Path:

Huawei Cloud Console → LTS → Log Management → `prod-checkout` → `application-access` → SQL Query

LTS SQL Query 2 — Successful logins from brute-force source IPs

```
SELECT source_ip,
       username,
       COUNT(*) AS successful_logins,
       MIN(timestamp) AS first_success,
       MAX(timestamp) AS last_success
FROM   log
WHERE  request_uri = '/api/login'
AND    status = 200
AND    timestamp >= CURRENT_TIMESTAMP - INTERVAL '30' MINUTE
AND    source_ip IN (
  SELECT source_ip
  FROM   log
  WHERE  request_uri = '/api/login'
  AND    status = 401
  AND    timestamp >= CURRENT_TIMESTAMP - INTERVAL '30' MINUTE
  GROUP BY source_ip
  HAVING COUNT(*) > 200
)
GROUP BY source_ip, username
ORDER BY successful_logins DESC;
```

Expected Evidence:

- If no rows are returned, the brute-force attempt did not result in successful authentication during the window.
 - If rows are returned, the listed usernames may be compromised and should be locked, forced to reset passwords, and reviewed for post-login activity.
 - The `first_success` timestamp becomes a key incident timeline marker.
-

Action 2.3 — Confirm traffic pattern over time

Action: Determine whether the attack is still active and whether it coincides with the CPU spike.

Huawei Cloud Service: LTS

Console Path:

Huawei Cloud Console → LTS → Log Management → prod-checkout → application-access → SQL Query

LTS SQL Query 3 — Failed login attempts over time

```
SELECT DATE_TRUNC('minute', timestamp) AS minute_bucket,
       source_ip,
       COUNT(*) AS failed_attempts
FROM   log
WHERE  request_uri = '/api/login'
AND    status = 401
AND    timestamp BETWEEN TIMESTAMP '03:00:00' AND TIMESTAMP '04:00:00'
GROUP BY DATE_TRUNC('minute', timestamp), source_ip
ORDER BY minute_bucket ASC, failed_attempts DESC;
```

Expected Evidence:

- Per-minute attack rate.
 - Whether the brute-force activity begins before, during, or after the CPU alarm.
 - Whether blocking the IP reduces CPU pressure.
-

Action 2.4 — Block attacker IP at the perimeter

Action: Block the attacker IP before it reaches the checkout service.

Huawei Cloud Service: WAF, or SecMaster one-click blocking integrated with WAF/CFW/VPC/IAM

Console Path Option A — WAF:

Huawei Cloud Console → Web Application Firewall → Policies → Blacklist and Whitelist → Add Rule → Block source_ip

Console Path Option B — SecMaster:

Huawei Cloud Console → SecMaster → Workspaces → Alerts / Incidents → Alert Detail → One-Click Blocking

Huawei Cloud WAF supports blacklist and whitelist rules to block or allow requests from specified IP addresses or address ranges. Huawei Cloud SecMaster also supports one-click blocking; Huawei documentation states that if an IP address, IP address range, or IAM user is added to a blacklist, CFW, WAF, VPC, and IAM can block requests from that object.

Expected Evidence:

- WAF blacklist rule created for the attacker IPs.
 - Drop in HTTP 401 attempts in LTS.
 - Drop in CPU or network traffic if brute force contributed to load.
 - Change record in CTS showing who added the block rule.
-

Event 3 — 03:32:11 UTC

SecMaster Alert: SQL Injection Attempt Blocked by WAF

Situation

SecMaster alert appears:

“Confirmed SQL injection attempt from known malicious IP 198.51.100.77 — blocked by WAF, source IP correlated with threat intel feed.”

Huawei Cloud SecMaster aggregates alerts from security services, correlates signals, and can convert or associate alerts into incidents. Its alert details page shows alert names, types, severity levels, and details for investigation.

Action 3.1 — Open full incident detail and correlated signals

Action: Review the alert, correlation, and incident context.

Huawei Cloud Service: SecMaster

Console Path:

Huawei Cloud Console → SecMaster → Workspaces → Security Operations → Alerts / Incidents → Search source IP 198.51.100.77 → Alert Detail / Incident Detail

Expected Evidence:

- Alert name: confirmed SQL injection attempt.
 - Source IP: 198.51.100.77.
 - Destination domain, URI, method, and request ID.
 - WAF action: blocked.
 - Threat intelligence correlation: known malicious IP.
 - Severity and confidence.
 - Related alerts or correlated events.
 - Timeline of the attack attempt.
-

Action 3.2 — Determine whether the request appears in application logs

Question: WAF blocked the request. Does it appear in application logs?

Answer:

Usually, no. If WAF blocks the request at the edge before forwarding it to ELB/ECS, the application never receives the request. Therefore, the application access log may not contain the malicious SQL injection payload. However, the request should appear in WAF logs, SecMaster alert detail, and possibly LTS if WAF logs are delivered to LTS.

Expected Evidence:

- WAF log entry showing the blocked request.
 - No matching application log entry on ECS for the same request ID or payload.
 - SecMaster incident correlation proving that WAF blocked the request before application delivery.
-

Action 3.3 — Collect evidence for regulator incident report

Evidence 1 — WAF Block Log

- **Source:** WAF logs delivered to LTS.

- **Stored in:** `OBS evidence bucket /incident-YYYYMMDD/waf/`
- **Purpose:** Proves that the SQL injection attempt was blocked before reaching the application.

Evidence 2 — SecMaster Incident Detail

- **Source:** SecMaster alert/incident export.
- **Stored in:** `OBS evidence bucket /incident-YYYYMMDD/secmaster/`
- **Purpose:** Shows correlation with threat intelligence and incident severity.

Evidence 3 — CTS Change and Response Trail

- **Source:** CTS traces for WAF/SecMaster response actions.
- **Stored in:** `OBS evidence bucket /incident-YYYYMMDD/cts/`
- **Purpose:** Shows who reviewed the alert, who created blocking rules, and when response actions were performed.

CTS records details about operations performed by tenants, such as creating, modifying, and deleting cloud service resources. Huawei documentation also states that CTS traces can be transferred to OBS for long-term storage beyond the default trace retention window.

Event 4 — 04:47:53 UTC

CTS Key Event: OBS Bucket Deleted by `contractor.bila1`

Situation

CTS sends a key-event notification:

- IAM user: `contractor.bila1`
- Action: deleted OBS bucket `acme-customer-data-backups`
- Source IP: `45.142.x.x`
- Source IP does not match corporate VPN egress range.

This is the most serious event because it indicates possible credential compromise or malicious insider activity and directly affects backup integrity.

Action 4.1 — Extract CTS fields as evidence

Action: Extract the core fields from the CTS trace JSON.

Huawei Cloud Service: Cloud Trace Service / CTS

Console Path:

Huawei Cloud Console → Cloud Trace Service → Trace List → Search
deleteBucket / OBS / contractor.bilal

Huawei Cloud CTS trace structure consists of key fields displayed in the CTS console. CTS traces record cloud service resource operations and are used to identify who performed operations and when.

Five CTS JSON Fields to Extract:

1. `user`
2. `user_name`
3. `source_ip`
4. `trace_name`
5. `event_time`

Additional useful fields:

6. `trace_type`
7. `service_type`
8. `resource_type`
9. `resource_name`
10. `request`
11. `response`
12. `trace_id`

Expected Evidence:

- `user_name = contractor.bilal`
- `source_ip = 45.142.x.x`
- `trace_name = deleteBucket` or equivalent OBS bucket deletion operation
- `resource_name = acme-customer-data-backups`
- `event_time = 04:47:53 UTC`
- `trace_type = ConsoleAction` or `ApiCall`

Action 4.2 — CTS Trace List filter set for all actions by `contractor.bilal`

Action: Find every action performed by `contractor.bilal` in the last 24 hours.

Huawei Cloud Service: CTS

Console Path:

Huawei Cloud Console → Cloud Trace Service → Trace List

Exact Filter Set:

- **Time Range:** Last 24 hours
- **Trace Source / Service Type:** All services first; then narrow to OBS, IAM, ECS, VPC, WAF, KMS if needed
- **User:** contractor.bilal
- **Trace Type:** ConsoleAction and ApiCall
- **Resource Type:** All resource types first; then bucket, object, agency, user, policy, access key
- **Trace Name:** Leave blank for full activity review; then search specific actions:
 - deleteBucket
 - deleteObject
 - putBucketPolicy
 - deleteBucketPolicy
 - createAccessKey
 - updateLoginProfile
 - createAgency
 - putObject
 - getObject
 - listBucket
- **Resource Name:** acme-customer-data-backups when focusing on the deleted bucket

Expected Evidence:

- Whether the user only deleted the bucket or performed reconnaissance first.
- Whether access keys were created or used.
- Whether bucket policy, IAM policy, or agency permissions were modified before deletion.
- Whether other sensitive resources were accessed.
- Whether actions were performed from the same suspicious IP.

Action 4.3 — First IAM defensive action

Action: Contain the identity without destroying evidence.

Huawei Cloud Service: IAM

Console Path:

Huawei Cloud Console → Identity and Access Management → Users → `contractor.bilal`

First Defensive Action:

Disable the user's access and revoke active credentials, but do not delete the user.

Specific Steps:

1. Disable console login for `contractor.bilal`.
2. Disable or delete access keys.
3. Remove the user from high-risk groups.
4. Revoke temporary credentials if applicable.
5. Preserve the IAM user object, group memberships, policies, and CTS traces as evidence.

Reasoning:

Deleting the user immediately can destroy context and make the forensic timeline harder to reconstruct. The priority is containment plus evidence preservation.

Action 4.4 — Determine whether OBS deletion is recoverable

Question: Is the data actually gone?

Answer:

It depends on OBS protection settings. If OBS versioning was disabled and objects were manually deleted, Huawei Cloud documentation states that deleted or overwritten OBS data cannot be recovered. If versioning was enabled before deletion, previous object versions may be recoverable. If WORM retention was enabled, protected object versions cannot be deleted during the retention period.

Recovery Workflow:

1. Check whether OBS bucket versioning was enabled.
2. Check whether WORM retention was enabled.
3. Check lifecycle rules for automatic deletion.
4. Check cross-region replication or backup copies.
5. If versioning is enabled, restore deleted object versions.
6. If WORM retention is enabled, verify whether deletion was blocked or only delete markers were created.
7. If neither versioning, WORM, nor backups exist, treat the bucket deletion as permanent data loss and escalate immediately.

Console Path:

Huawei Cloud Console → Object Storage Service → Bucket List → acme-customer-data-backups → Objects / Versions / WORM / Lifecycle Rules

Expected Evidence:

- Versioning status.
 - WORM retention status.
 - Deleted object versions or delete markers.
 - Lifecycle rule history.
 - Replication or backup status.
 - Final recovery decision.
-

LTS SQL Query Appendix

Query 1 — Identify usernames targeted by brute force

```
SELECT username,
       source_ip,
       COUNT(*) AS failed_attempts
FROM   log
WHERE  request_uri = '/api/login'
AND    status = 401
AND    source_ip IN (
    SELECT source_ip
    FROM   log
    WHERE  request_uri = '/api/login'
    AND    status = 401
    GROUP BY source_ip
    HAVING COUNT(*) > 200
)
GROUP BY username, source_ip
ORDER BY failed_attempts DESC
LIMIT 50;
```

Query 2 — Check successful logins from attacker IPs

```
SELECT source_ip,
       username,
       COUNT(*) AS successful_logins,
       MIN(timestamp) AS first_success,
       MAX(timestamp) AS last_success
FROM   log
```

```

WHERE request_uri = '/api/login'
AND status = 200
AND timestamp >= CURRENT_TIMESTAMP - INTERVAL '30' MINUTE
AND source_ip IN (
    SELECT source_ip
    FROM log
    WHERE request_uri = '/api/login'
    AND status = 401
    AND timestamp >= CURRENT_TIMESTAMP - INTERVAL '30' MINUTE
    GROUP BY source_ip
    HAVING COUNT(*) > 200
)
GROUP BY source_ip, username
ORDER BY successful_logins DESC;

```

Query 3 — Failed login attempts over time

```

SELECT DATE_TRUNC('minute', timestamp) AS minute_bucket,
       source_ip,
       COUNT(*) AS failed_attempts
FROM log
WHERE request_uri = '/api/login'
AND status = 401
AND timestamp BETWEEN TIMESTAMP '03:00:00' AND TIMESTAMP '04:00:00'
GROUP BY DATE_TRUNC('minute', timestamp), source_ip
ORDER BY minute_bucket ASC, failed_attempts DESC;

```

Query 4 — Post-login activity for compromised usernames

```

SELECT username,
       source_ip,
       request_uri,
       status,
       COUNT(*) AS requests
FROM log
WHERE username IN (
    SELECT username
    FROM log
    WHERE request_uri = '/api/login'
    AND status = 200
    AND timestamp >= CURRENT_TIMESTAMP - INTERVAL '30' MINUTE'
)
AND timestamp >= CURRENT_TIMESTAMP - INTERVAL '30' MINUTE
GROUP BY username, source_ip, request_uri, status
ORDER BY requests DESC
LIMIT 100;

```

Note: Field names such as `username`, `timestamp`, `request_uri`, `status`, and `source_ip` must be adjusted to match the actual structured parsing fields in Acme Retail's LTS log stream.

Synthesis

Which event was the most dangerous, and why?

The most dangerous event was Event 4: the OBS backup bucket deletion by `contractor.bilal` from a non-corporate IP. The CPU spike, brute-force login campaign, and SQL injection attempt were loud and operationally urgent, but Event 4 directly affected backup integrity and may indicate credential compromise or malicious insider activity. A deleted backup bucket can turn a security incident into a business continuity and regulatory incident, especially if versioning, WORM retention, or replication were not enabled.

CEO Briefing — Three Sentences

Overnight, we detected high checkout CPU load, a brute-force login campaign, and a SQL injection attempt that was blocked by WAF.

The most serious issue is that an IAM user deleted the `acme-customer-data-backups` OBS bucket from a non-corporate IP, which may indicate credential compromise and potential backup loss.

We have contained the identity, are preserving CTS, LTS, WAF, SecMaster, and OBS evidence, and are validating whether recovery is possible through OBS versioning, WORM retention, or backup replication.

Which Huawei Cloud feature could have prevented Event 4 entirely?

The strongest preventive control would have been a least-privilege IAM policy that explicitly denies OBS bucket deletion for contractor accounts, combined with MFA and source-IP conditions.

A specific control would be:

IAM policy: deny `obs:DeleteBucket` and destructive OBS actions unless the principal is an approved break-glass administrator, authenticated with MFA, and connecting from the corporate VPN egress IP range.

Additional preventive controls:

- OBS WORM retention for backup objects.
 - OBS versioning for backup buckets.
 - CTS key event notifications for destructive actions.
 - SecMaster playbook to automatically disable suspicious IAM users.
 - Separation of duties: contractors should never have permission to delete production backup buckets.
-

Optional Stretch Goal — SecMaster SOAR Playbook YAML

playbook_name: acme-retail-cloud-incident-response

description: >

SOAR-style response playbook for brute-force login, WAF SQL injection, and suspicious OBS bucket deletion in Huawei Cloud TR-Istanbul.

trigger:

source: SecMaster

conditions:

- alert_type in ["Brute Force", "SQL Injection", "Suspicious IAM Activity"]
- severity in ["High", "Critical"]

steps:

- name: enrich_alert

action: query_context

services:

- SecMaster
- LTS
- CTS

outputs:

- source_ip
- username
- resource_name
- trace_id
- related_alerts

- name: block_malicious_ip

condition: source_ip is not null

action: block_ip

target_services:

- WAF
- CFW

parameters:

ip: "{{ source_ip }}"
duration: "24h"
reason: "Automated block from SecMaster incident"

- name: contain_suspicious_identity
condition: username contains "contractor" or alert_type == "Suspicious IAM Activity"
action: disable_identity
target_service: IAM
parameters:
 - user: "{{ username }}"
 - preserve_user_object: true
 - disable_access_keys: true
 - disable_console_login: true
- name: snapshot_evidence
action: export_evidence
target_service: OBS
parameters:
 - bucket: "acme-security-evidence"
 - path: "incidents/{{ incident_id }}/"
 - include:
 - SecMaster incident detail
 - CTS traces
 - LTS query results
 - WAF logs
 - OBS bucket configuration
- name: notify_on_call
action: send_notification
target_service: SMN
parameters:
 - topic: "security-on-call"
 - message: "Critical cloud security incident {{ incident_id }} requires review."
- name: open_ticket
action: webhook
parameters:
 - url: "https://tickets.acme.example/api/incidents"
 - method: POST
 - payload:
 - incident_id: "{{ incident_id }}"
 - severity: "{{ severity }}"
 - summary: "{{ alert_name }}"
 - evidence_path: "obs://acme-security-evidence/incidents/{{ incident_id }}/"